

Manual de Base de Datos y Respaldo

DataLegal

Guía compacta de arquitectura, integridad, respaldo, restauración y continuidad

Versión 1.0

Corte de evidencia: 14 de agosto de 2026

Audiencia: ingeniería, DevOps, seguridad, soporte y responsables de continuidad

Clasificación: uso interno

Basado exclusivamente en artefactos locales verificables. Los recursos AWS no comprobados se expresan como placeholders o decisiones de operación.

Contenido y rutas de uso

Esta tabla funciona como mapa operativo; evita números de página estáticos que puedan desactualizarse al regenerar el documento.

Sección	Contenido	Uso principal
1–2	Alcance, evidencia, arquitectura y modelo lógico	Orientación e impacto de diseño
3–4	Diccionario, relaciones e integridad	Desarrollo, revisión de cambios y diagnóstico
5–7	Migraciones, configuración local y AWS parametrizable	Despliegue y cambios controlados
8–9	Estado actual y estrategia de respaldo	Diseño de continuidad y automatización
10–13	Restauración, RPO/RTO, validación, simulacros y escenarios	Respuesta y recuperación
14–16	Seguridad, checklists y bitácoras	Ejecución controlada y evidencia
A–C	Comandos, placeholders y fuentes	Consulta rápida y auditoría

Convenciones de evidencia

IMPLEMENTADO Comportamiento encontrado en código, modelos, migraciones o scripts del repositorio.

VERIFICADO Resultado obtenido mediante inspección local de artefactos, sin cambiar su contenido.

PROPUESTO Procedimiento recomendado para cerrar una brecha; requiere aprobación y automatización.

DECISIÓN Parámetro que el responsable de operación debe resolver antes de producción.

Lectura de emergencia

- ☐ Si hay pérdida o corrupción: aislar la escritura, abrir la sección 13 y elegir el escenario.
- ☐ Antes de restaurar: preservar evidencia, identificar el punto objetivo y validar el artefacto fuera de producción.
- ☐ Después de restaurar: ejecutar integridad, pruebas funcionales, reconciliación y cierre de bitácora.

1. Propósito, alcance y evidencia

Este manual describe el modelo de datos observable y establece un runbook de respaldo y restauración. Las instrucciones propuestas no se presentan como capacidades ya desplegadas.

HALLAZGO ESTRUCTURAL No existe un esquema Prisma en el repositorio inspeccionado. La fuente de verdad observable son los modelos SQLAlchemy 2.0 y las migraciones Alembic.

Dimensión	Resultado verificable	Implicación
Modelo	33 tablas, 379 columnas, 43 restricciones FK explícitas	El diccionario se genera desde metadata SQLAlchemy.
Motores	SQLite predeterminado local; PostgreSQL 16 en Docker Compose	Los procedimientos de copia y restauración son distintos por motor.
Migraciones	Una cabeza Alembic: d4e5f6a7b8c9	Todo cambio de esquema debe converger en esa cadena.
Tenancy	tenant_id requerido en 29 tablas y opcional en 2	El aislamiento depende también de filtros de aplicación.
AWS	Hay documentación y script de despliegue; el estado real no se validó	Usar placeholders hasta comprobar cuenta, región y recursos.

1.1 Fuera de alcance

- ☐ Validar el estado de una cuenta AWS, una instancia, un bucket, una clave KMS o un servicio RDS.
- ☐ Reproducir valores de archivos de entorno, contraseñas, tokens, cadenas de conexión o credenciales de demostración.
- ☐ Prometer tiempos de recuperación no demostrados mediante un simulacro cronometrado.
- ☐ Definir por sí solo plazos legales de retención; deben ser aprobados por negocio, legal y seguridad.

Fuente verificable: backend/app/db/base.py; backend/app/models/*.py; backend/alembic/versions/*.py; backend/app/core/config.py; docker-compose.yml.

2. Arquitectura y modelo lógico

2.1 Arquitectura observable

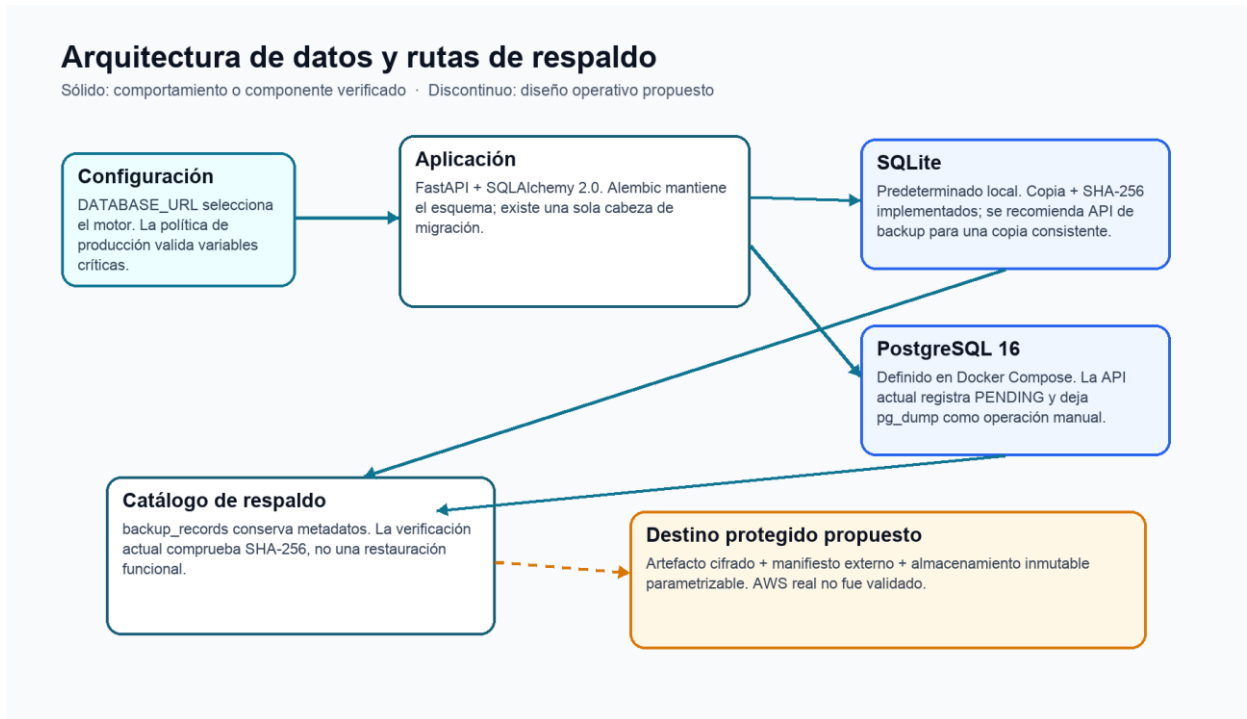


Figura 1. Arquitectura verificada y frontera del diseño propuesto.

Capa	Implementación observable	Notas de operación
Configuración	Settings lee variables de entorno; DATABASE_URL selecciona el motor	Producción falla si faltan SECRET_KEY, MFA_ENCRYPTION_KEY o CORS_ORIGINS.
ORM	SQLAlchemy 2.0 declarativo	TimestampMixin aporta created_at y updated_at.
Migraciones	Alembic con compare_type=True y NullPool	Usar upgrade head; create_all/drop_all se documentan solo para desarrollo/pruebas.
SQLite	Valor predeterminado local	La sesión agrega check_same_thread=False; no se encontró activación explícita de PRAGMA foreign_keys.
PostgreSQL	Imagen postgres:16-alpine en Compose	El contenedor backend ejecuta Alembic antes de iniciar la aplicación.
Respaldo	Copia SQLite + SHA-256; PostgreSQL queda PENDING/manual	La estrategia endurecida de las secciones 9–10 es una propuesta.

2.2 Modelo lógico por dominios

Modelo lógico por dominios

Las líneas sólidas resumen FK observables. La línea discontinua representa alcance tenant sin FK física.

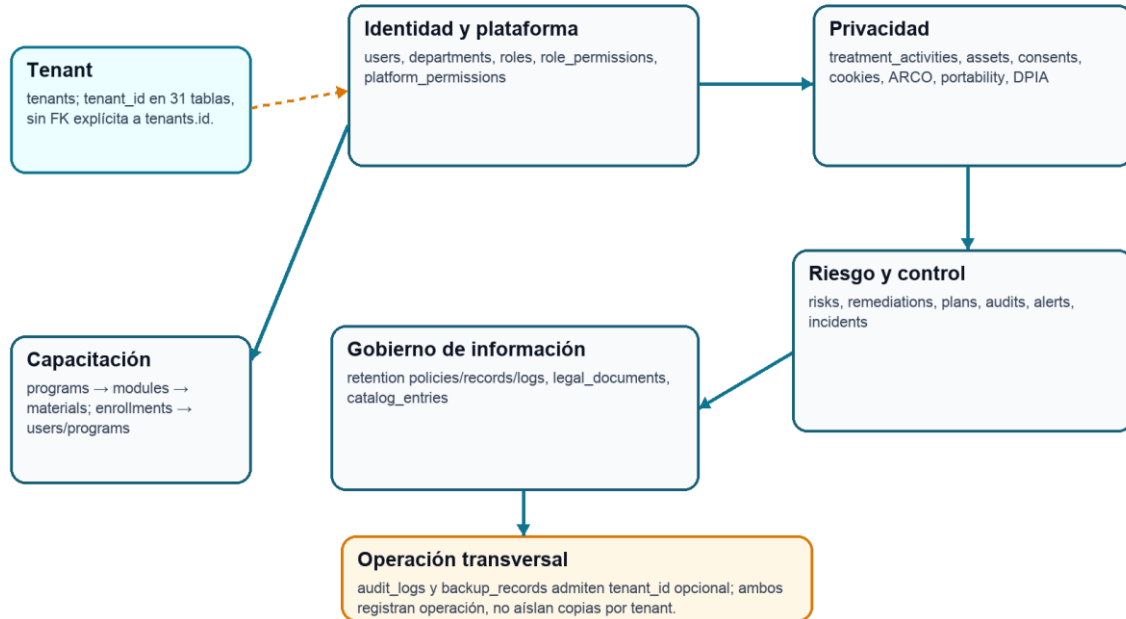


Figura 2. Agrupación lógica; el diccionario de la sección 3 contiene las relaciones exactas.

RIESGO DE INTEGRIDAD TenantBase define tenant_id como entero obligatorio e indexado, pero no como FK a tenants.id. audit_logs y backup_records admiten tenant_id nulo. El aislamiento debe comprobarse en consultas, autorización, pruebas y procedimientos de respaldo.

Fuente verificable: backend/app/db/base.py y metadata SQLAlchemy cargada desde backend/app/models/*.py.

3. Diccionario de entidades

El inventario siguiente fue generado desde Base.metadata. “—” significa que la metadata no declara valor para ese atributo; no implica necesariamente ausencia de lógica en la aplicación.

3.1 Catálogo de entidades

Dominio	Tabla	Función observable	Cols./FK	tenant_id
Identidad y plataforma	tenants	Organizaciones raíz de la aplicación; RUC único.	13 / 0	Sin tenant_id
Identidad y plataforma	users	Cuentas de usuario, autenticación, alcance y pertenencia organizativa.	16 / 1	Requerido
Identidad y plataforma	departments	Unidades organizativas y jefatura opcional.	6 / 1	Requerido
Identidad y plataforma	roles	Roles personalizados por tenant.	6 / 0	Requerido
Identidad y plataforma	role_permissions	Permisos por módulo asociados a roles.	7 / 1	Requerido
Identidad y plataforma	platform_permissions	Permisos de plataforma asociados directamente a usuarios.	5 / 1	Sin tenant_id
Privacidad y tratamiento	treatment_activities	Registro de actividades de tratamiento de datos.	17 / 2	Requerido
Privacidad y tratamiento	information_assets	Inventario de activos de información y sus responsables.	13 / 3	Requerido
Privacidad y tratamiento	consent_records	Evidencias de consentimiento vinculables a tratamientos.	14 / 2	Requerido
Privacidad y tratamiento	cookie_banners	Configuraciones de banners de cookies.	9 / 1	Requerido
Privacidad y tratamiento	cookie_consent	Decisiones de consentimiento registradas para banners.	9 / 1	Requerido

3.1 Catálogo de entidades — bloque 2 de 3

Dominio	Tabla	Función observable	Cols./FK	tenant_id
Privacidad y tratamiento	arco_requests	Solicitudes de derechos ARCO y su trazabilidad operativa.	17 / 1	Requerido
Privacidad y tratamiento	portability_requests	Solicitudes de portabilidad y estado de entrega.	11 / 0	Requerido
Privacidad y tratamiento	dpia_assessments	Evaluaciones de impacto vinculables a tratamientos.	13 / 2	Requerido
Riesgo, auditoría e incidentes	risk_assessments	Evaluaciones de riesgo y analista asignado.	13 / 2	Requerido
Riesgo, auditoría e incidentes	remediations	Acciones de remediación vinculables a riesgos y responsables.	16 / 3	Requerido
Riesgo, auditoría e incidentes	action_plan_templates	Plantillas reutilizables para planes de acción.	9 / 0	Requerido
Riesgo, auditoría e incidentes	action_plans	Planes de acción creados desde riesgos o plantillas.	13 / 3	Requerido
Riesgo, auditoría e incidentes	audit_plans	Planes de auditoría y auditor asignado.	11 / 1	Requerido
Riesgo, auditoría e incidentes	audit_findings	Hallazgos vinculados a planes de auditoría.	13 / 2	Requerido
Riesgo, auditoría e incidentes	audit_logs	Eventos de auditoría registrados por la aplicación.	8 / 1	Opcional
Riesgo, auditoría e incidentes	alerts	Alertas operativas y destinatario opcional.	13 / 1	Requerido

3.1 Catálogo de entidades — bloque 3 de 3

Dominio	Tabla	Función observable	Cols./FK	tenant_id
Riesgo, auditoría e incidentes	incidents	Incidentes de seguridad y campos de notificación/cierre SSPDP.	26 / 3	Requerido
Retención, documentos y catálogo	retention_policies	Políticas de retención configuradas por tenant.	10 / 0	Requerido
Retención, documentos y catálogo	retention_records	Aplicación de políticas de retención a activos.	13 / 3	Requerido
Retención, documentos y catálogo	retention_execution_logs	Resultados de ejecuciones de políticas de retención.	11 / 2	Requerido
Retención, documentos y catálogo	legal_documents	Documentos legales y metadatos de creación.	12 / 1	Requerido
Retención, documentos y catálogo	catalog_entries	Entradas de catálogo actualizables por usuario.	13 / 1	Requerido
Capacitación	training_programs	Programas de capacitación.	7 / 0	Requerido
Capacitación	training_modules	Módulos pertenecientes a programas de capacitación.	8 / 1	Requerido
Capacitación	training_materials	Materiales pertenecientes a módulos.	9 / 1	Requerido
Capacitación	enrollments	Inscripciones de usuarios en programas de capacitación.	9 / 2	Requerido
Respaldo	backup_records	Catálogo de ejecuciones de respaldo y verificaciones.	9 / 0	Opcional

3.2 Diccionario físico de campos

Cada fila conserva el nombre, tipo, nulabilidad, claves/relaciones y valor predeterminado declarados por SQLAlchemy. Los bloques son puramente de paginación; no alteran la agrupación lógica.

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
tenants	id	INTEGER	No	PK; IDX	—
tenants	name	VARCHAR(255)	No	—	—
tenants	ruc	VARCHAR(20)	No	UQ; IDX	—
tenants	country	VARCHAR(100)	No	—	Ecuador
tenants	sector	VARCHAR(255)	Sí	—	—
tenants	is_active	BOOLEAN	No	—	True
tenants	address	VARCHAR(500)	Sí	—	—
tenants	website	VARCHAR(255)	Sí	—	—
tenants	dpo_name	VARCHAR(255)	Sí	—	—
tenants	dpo_email	VARCHAR(255)	Sí	—	—
tenants	dpo_phone	VARCHAR(50)	Sí	—	—
tenants	created_at	DATETIME	No	—	now()
tenants	updated_at	DATETIME	No	—	now()
users	id	INTEGER	No	PK; IDX	—
users	email	VARCHAR(255)	No	UQ; IDX	—
users	hashed_password	VARCHAR(255)	No	—	—
users	full_name	VARCHAR(255)	No	—	—
users	role	VARCHAR(50)	No	—	AUDITOR
users	account_scope	VARCHAR(20)	No	—	TENANT
users	department_id	INTEGER	Sí	FK→departments.id	—

3.2 Diccionario físico — bloque 2 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
users	is_active	BOOLEAN	No	—	True
users	failed_attempts	INTEGER	No	—	0
users	locked_until	DATETIME	Sí	—	—
users	mfa_secret	VARCHAR(255)	Sí	—	—
users	mfa_enabled	BOOLEAN	No	—	False
users	last_activity_at	DATETIME	Sí	—	—
users	tenant_id	INTEGER	No	IDX	—
users	created_at	DATETIME	No	—	now()
users	updated_at	DATETIME	No	—	now()
departments	id	INTEGER	No	PK; IDX	—
departments	name	VARCHAR(255)	No	—	—
departments	head_user_id	INTEGER	Sí	FK→users.id	—
departments	tenant_id	INTEGER	No	IDX	—
departments	created_at	DATETIME	No	—	now()
departments	updated_at	DATETIME	No	—	now()
roles	id	INTEGER	No	PK; IDX	—
roles	name	VARCHAR(50)	No	IDX	—
roles	description	VARCHAR(255)	No	—	—
roles	tenant_id	INTEGER	No	IDX	—
roles	created_at	DATETIME	No	—	now()

3.2 Diccionario físico — bloque 3 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
roles	updated_at	DATETIME	No	—	now()
role_permissions	id	INTEGER	No	PK; IDX	—
role_permissions	role_id	INTEGER	No	IDX; FK→roles.id	—
role_permissions	module	VARCHAR(100)	No	—	—
role_permissions	actions	JSON	No	—	callable
role_permissions	tenant_id	INTEGER	No	IDX	—
role_permissions	created_at	DATETIME	No	—	now()
role_permissions	updated_at	DATETIME	No	—	now()
platform_permissions	id	INTEGER	No	PK; IDX	—
platform_permissions	user_id	INTEGER	No	IDX; FK→users.id	—
platform_permissions	permission	VARCHAR(100)	No	IDX	—
platform_permissions	created_at	DATETIME	No	—	now()
platform_permissions	updated_at	DATETIME	No	—	now()
treatment_activities	id	INTEGER	No	PK; IDX	—
treatment_activities	name	VARCHAR(255)	No	—	—
treatment_activities	purpose	TEXT	No	—	—
treatment_activities	legal_basis	VARCHAR(100)	No	—	—
treatment_activities	personal_data_types	JSON	No	—	callable
treatment_activities	data_subjects	JSON	No	—	callable
treatment_activities	retention_period_days	INTEGER	No	—	365

3.2 Diccionario físico — bloque 4 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
treatment_activities	is_cross_border	BOOLEAN	No	—	False
treatment_activities	destination_countries	JSON	Sí	—	callable
treatment_activities	processor_name	VARCHAR(255)	Sí	—	—
treatment_activities	processor_country	VARCHAR(100)	Sí	—	—
treatment_activities	department_id	INTEGER	Sí	IDX; FK→departments.id	—
treatment_activities	owner_id	INTEGER	Sí	FK→users.id	—
treatment_activities	status	VARCHAR(50)	No	—	DRAFT
treatment_activities	tenant_id	INTEGER	No	IDX	—
treatment_activities	created_at	DATETIME	No	—	now()
treatment_activities	updated_at	DATETIME	No	—	now()
information_assets	id	INTEGER	No	PK; IDX	—
information_assets	name	VARCHAR(255)	No	—	—
information_assets	description	TEXT	No	—	—
information_assets	asset_type_code	VARCHAR(100)	No	—	—
information_assets	format_code	VARCHAR(100)	No	—	—
information_assets	storage_medium_code	VARCHAR(100)	No	—	—
information_assets	classification_level_code	VARCHAR(100)	No	—	—
information_assets	treatment_activity_id	INTEGER	Sí	IDX; FK→treatment_activities.id	—
information_assets	department_id	INTEGER	Sí	IDX; FK→departments.id	—
information_assets	owner_id	INTEGER	Sí	FK→users.id	—

3.2 Diccionario físico — bloque 5 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
information_assets	tenant_id	INTEGER	No	IDX	—
information_assets	created_at	DATETIME	No	—	now()
information_assets	updated_at	DATETIME	No	—	now()
consent_records	id	INTEGER	No	PK; IDX	—
consent_records	treatment_activity_id	INTEGER	Sí	IDX; FK→treatment_activities.id	—
consent_records	data_subject_token	VARCHAR(255)	No	IDX	—
consent_records	legal_basis	VARCHAR(100)	No	—	—
consent_records	purpose	TEXT	No	—	—
consent_records	is_sensitive	BOOLEAN	No	—	False
consent_records	granted_at	DATETIME	No	—	now()
consent_records	is_revoked	BOOLEAN	No	IDX	False
consent_records	revoked_at	DATETIME	Sí	—	—
consent_records	revocation_reason	TEXT	No	—	—
consent_records	created_by_id	INTEGER	Sí	FK→users.id	—
consent_records	tenant_id	INTEGER	No	IDX	—
consent_records	created_at	DATETIME	No	—	now()
consent_records	updated_at	DATETIME	No	—	now()
cookie_banners	id	INTEGER	No	PK; IDX	—
cookie_banners	version	VARCHAR(50)	No	—	—
cookie_banners	content	TEXT	No	—	—

3.2 Diccionario físico — bloque 6 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
cookie_banners	effective_date	DATETIME	No	—	—
cookie_banners	is_active	BOOLEAN	No	—	True
cookie_banners	created_by_id	INTEGER	Sí	FK→users.id	—
cookie_banners	tenant_id	INTEGER	No	IDX	—
cookie_banners	created_at	DATETIME	No	—	now()
cookie_banners	updated_at	DATETIME	No	—	now()
cookie_consent	id	INTEGER	No	PK; IDX	—
cookie_consent	banner_id	INTEGER	No	IDX; FK→cookie_banners.id	—
cookie_consent	data_subject_token	VARCHAR(255)	No	IDX	—
cookie_consent	accepted_at	DATETIME	No	—	now()
cookie_consent	revoked_at	DATETIME	Sí	—	—
cookie_consent	is_revoked	BOOLEAN	No	—	False
cookie_consent	tenant_id	INTEGER	No	IDX	—
cookie_consent	created_at	DATETIME	No	—	now()
cookie_consent	updated_at	DATETIME	No	—	now()
arco_requests	id	INTEGER	No	PK; IDX	—
arco_requests	ticket_number	VARCHAR(50)	No	UQ; IDX	—
arco_requests	request_type	VARCHAR(50)	No	IDX	—
arco_requests	requester_name	VARCHAR(255)	No	—	—
arco_requests	requester_email	VARCHAR(255)	No	—	—

3.2 Diccionario físico — bloque 7 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
arco_requests	requester_id_number	VARCHAR(50)	No	—	—
arco_requests	description	TEXT	No	—	—
arco_requests	status	VARCHAR(50)	No	IDX	RECEIVED
arco_requests	received_date	DATE	No	—	—
arco_requests	deadline_date	DATE	No	—	—
arco_requests	assigned_dpo_id	INTEGER	Sí	FK→users.id	—
arco_requests	response_text	TEXT	No	—	—
arco_requests	responded_at	DATETIME	Sí	—	—
arco_requests	rejection_reason	TEXT	No	—	—
arco_requests	tenant_id	INTEGER	No	IDX	—
arco_requests	created_at	DATETIME	No	—	now()
arco_requests	updated_at	DATETIME	No	—	now()
portability_requests	id	INTEGER	No	PK; IDX	—
portability_requests	subject_name	VARCHAR(255)	No	—	—
portability_requests	subject_email	VARCHAR(255)	No	IDX	—
portability_requests	request_date	DATETIME	No	—	—
portability_requests	status	VARCHAR(50)	No	IDX	PENDING
portability_requests	response_data	TEXT	Sí	—	—
portability_requests	completed_at	DATETIME	Sí	—	—
portability_requests	notes	TEXT	No	—	—

3.2 Diccionario físico — bloque 8 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
portability_requests	tenant_id	INTEGER	No	IDX	—
portability_requests	created_at	DATETIME	No	—	now()
portability_requests	updated_at	DATETIME	No	—	now()
dpia_assessments	id	INTEGER	No	PK; IDX	—
dpia_assessments	treatment_activity_id	INTEGER	No	IDX; FK→treatment_activities.id	—
dpia_assessments	step1_description	TEXT	No	—	
dpia_assessments	step2_risk_analysis	TEXT	No	—	
dpia_assessments	step3_mitigations	TEXT	No	—	
dpia_assessments	status	VARCHAR(50)	No	IDX	DRAFT
dpia_assessments	signed_at	DATETIME	Sí	—	—
dpia_assessments	signed_by_id	INTEGER	Sí	FK→users.id	—
dpia_assessments	pdf_bytes	BLOB	Sí	—	—
dpia_assessments	version	INTEGER	No	—	1
dpia_assessments	tenant_id	INTEGER	No	IDX	—
dpia_assessments	created_at	DATETIME	No	—	now()
dpia_assessments	updated_at	DATETIME	No	—	now()
risk_assessments	id	INTEGER	No	PK; IDX	—
risk_assessments	treatment_activity_id	INTEGER	No	IDX; FK→treatment_activities.id	—
risk_assessments	analyst_id	INTEGER	Sí	FK→users.id	—
risk_assessments	responses	JSON	No	—	callable

3.2 Diccionario físico — bloque 9 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
risk_assessments	probability	INTEGER	No	—	1
risk_assessments	impact	INTEGER	No	—	1
risk_assessments	risk_score	INTEGER	No	—	1
risk_assessments	risk_level	VARCHAR(20)	No	—	LOW
risk_assessments	status	VARCHAR(50)	No	—	DRAFT
risk_assessments	notes	TEXT	No	—	
risk_assessments	tenant_id	INTEGER	No	IDX	—
risk_assessments	created_at	DATETIME	No	—	now()
risk_assessments	updated_at	DATETIME	No	—	now()
remediations	id	INTEGER	No	PK; IDX	—
remediations	risk_assessment_id	INTEGER	No	IDX; FK→risk_assessments.id	—
remediations	title	VARCHAR(255)	No	—	—
remediations	description	TEXT	No	—	
remediations	responsible_id	INTEGER	Sí	FK→users.id	—
remediations	due_date	DATE	Sí	—	—
remediations	completed_date	DATE	Sí	—	—
remediations	status	VARCHAR(50)	No	IDX	OPEN
remediations	risk_score_before	INTEGER	Sí	—	—
remediations	risk_score_after	INTEGER	Sí	—	—
remediations	risk_level_before	VARCHAR(20)	Sí	—	—

3.2 Diccionario físico — bloque 10 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
remediations	risk_level_after	VARCHAR(20)	Sí	—	—
remediations	created_by_id	INTEGER	Sí	FK→users.id	—
remediations	tenant_id	INTEGER	No	IDX	—
remediations	created_at	DATETIME	No	—	now()
remediations	updated_at	DATETIME	No	—	now()
action_plan_templates	id	INTEGER	No	PK; IDX	—
action_plan_templates	name	VARCHAR(255)	No	—	—
action_plan_templates	description	TEXT	No	—	—
action_plan_templates	applies_to_level	VARCHAR(20)	No	—	ANY
action_plan_templates	default_tasks	JSON	No	—	callable
action_plan_templates	is_active	BOOLEAN	No	—	True
action_plan_templates	tenant_id	INTEGER	No	IDX	—
action_plan_templates	created_at	DATETIME	No	—	now()
action_plan_templates	updated_at	DATETIME	No	—	now()
action_plans	id	INTEGER	No	PK; IDX	—
action_plans	risk_assessment_id	INTEGER	Sí	IDX; FK→risk_assessments.id	—
action_plans	template_id	INTEGER	Sí	FK→action_plan_templates.id	—
action_plans	title	VARCHAR(255)	No	—	—
action_plans	description	TEXT	No	—	—
action_plans	status	VARCHAR(50)	No	IDX	DRAFT

3.2 Diccionario físico — bloque 11 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
action_plans	tasks	JSON	No	—	callable
action_plans	target_date	DATE	Sí	—	—
action_plans	created_by_id	INTEGER	Sí	FK→users.id	—
action_plans	auto_generated	BOOLEAN	No	—	False
action_plans	tenant_id	INTEGER	No	IDX	—
action_plans	created_at	DATETIME	No	—	now()
action_plans	updated_at	DATETIME	No	—	now()
audit_plans	id	INTEGER	No	PK; IDX	—
audit_plans	name	VARCHAR(255)	No	—	—
audit_plans	scope	TEXT	No	—	—
audit_plans	period_start	DATE	Sí	—	—
audit_plans	period_end	DATE	Sí	—	—
audit_plans	auditor_id	INTEGER	Sí	FK→users.id	—
audit_plans	status	VARCHAR(50)	No	IDX	PLANNED
audit_plans	notes	TEXT	No	—	—
audit_plans	tenant_id	INTEGER	No	IDX	—
audit_plans	created_at	DATETIME	No	—	now()
audit_plans	updated_at	DATETIME	No	—	now()
audit_findings	id	INTEGER	No	PK; IDX	—
audit_findings	audit_plan_id	INTEGER	No	IDX; FK→audit_plans.id	—

3.2 Diccionario físico — bloque 12 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
audit_findings	title	VARCHAR(255)	No	—	—
audit_findings	description	TEXT	No	—	—
audit_findings	evidence	TEXT	No	—	—
audit_findings	severity	VARCHAR(20)	No	—	MEDIUM
audit_findings	status	VARCHAR(50)	No	IDX	OPEN
audit_findings	remediation_notes	TEXT	No	—	—
audit_findings	remediation_date	DATE	Sí	—	—
audit_findings	created_by_id	INTEGER	Sí	FK→users.id	—
audit_findings	tenant_id	INTEGER	No	IDX	—
audit_findings	created_at	DATETIME	No	—	now()
audit_findings	updated_at	DATETIME	No	—	now()
audit_logs	id	INTEGER	No	PK; IDX	—
audit_logs	tenant_id	INTEGER	Sí	IDX	—
audit_logs	user_id	INTEGER	Sí	IDX; FK→users.id	—
audit_logs	action	VARCHAR(100)	No	IDX	—
audit_logs	resource	VARCHAR(100)	No	—	—
audit_logs	detail	TEXT	No	—	—
audit_logs	ip_address	VARCHAR(50)	Sí	—	—
audit_logs	created_at	DATETIME	No	IDX	now()
alerts	id	INTEGER	No	PK; IDX	—

3.2 Diccionario físico — bloque 13 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
alerts	alert_type	VARCHAR(100)	No	IDX	—
alerts	title	VARCHAR(255)	No	—	—
alerts	message	TEXT	No	—	—
alerts	severity	VARCHAR(50)	No	—	INFO
alerts	resource_type	VARCHAR(100)	Sí	—	—
alerts	resource_id	INTEGER	Sí	—	—
alerts	recipient_id	INTEGER	Sí	IDX; FK→users.id	—
alerts	is_read	BOOLEAN	No	IDX	False
alerts	read_at	DATETIME	Sí	—	—
alerts	tenant_id	INTEGER	No	IDX	—
alerts	created_at	DATETIME	No	—	now()
alerts	updated_at	DATETIME	No	—	now()
incidents	id	INTEGER	No	PK; IDX	—
incidents	title	VARCHAR(255)	No	—	—
incidents	description	TEXT	No	—	—
incidents	incident_type	VARCHAR(100)	No	—	—
incidents	severity	VARCHAR(50)	No	—	MEDIUM
incidents	status	VARCHAR(50)	No	IDX	OPEN
incidents	vulnerability_types	JSON	No	—	callable
incidents	regulatory_notification_required	BOOLEAN	No	—	False

3.2 Diccionario físico — bloque 14 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
incidents	regulatory_notified_at	DATETIME	Sí	—	—
incidents	reporter_id	INTEGER	Sí	FK→users.id	—
incidents	assigned_to_id	INTEGER	Sí	FK→users.id	—
incidents	resolved_at	DATETIME	Sí	—	—
incidents	affected_data_types	TEXT	No	—	—
incidents	department_id	INTEGER	Sí	IDX; FK→departments.id	—
incidents	delegate_name	VARCHAR(255)	Sí	—	—
incidents	delegate_email	VARCHAR(255)	Sí	—	—
incidents	delegate_phone	VARCHAR(50)	Sí	—	—
incidents	controller_name	VARCHAR(255)	Sí	—	—
incidents	controller_email	VARCHAR(255)	Sí	—	—
incidents	controller_phone	VARCHAR(50)	Sí	—	—
incidents	closure_summary	TEXT	No	—	—
incidents	closure_report_pdf	BLOB	Sí	—	—
incidents	closed_at	DATETIME	Sí	—	—
incidents	tenant_id	INTEGER	No	IDX	—
incidents	created_at	DATETIME	No	—	now()
incidents	updated_at	DATETIME	No	—	now()
retention_policies	id	INTEGER	No	PK; IDX	—
retention_policies	name	VARCHAR(255)	No	—	—

3.2 Diccionario físico — bloque 15 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
retention_policies	data_category	VARCHAR(100)	No	IDX	—
retention_policies	retention_days	INTEGER	No	—	—
retention_policies	action_on_expiry	VARCHAR(50)	No	—	REVIEW
retention_policies	legal_basis	TEXT	No	—	
retention_policies	is_active	BOOLEAN	No	—	True
retention_policies	tenant_id	INTEGER	No	IDX	—
retention_policies	created_at	DATETIME	No	—	now()
retention_policies	updated_at	DATETIME	No	—	now()
retention_records	id	INTEGER	No	PK; IDX	—
retention_records	information_asset_id	INTEGER	No	IDX; FK→information_assets.id	—
retention_records	policy_id	INTEGER	Sí	FK→retention_policies.id	—
retention_records	expiry_date	DATE	No	—	—
retention_records	status	VARCHAR(50)	No	IDX	ACTIVE
retention_records	legal_hold	BOOLEAN	No	—	False
retention_records	hold_justification	TEXT	No	—	
retention_records	review_decision	VARCHAR(50)	Sí	—	—
retention_records	decision_rationale	TEXT	No	—	
retention_records	reviewed_by_id	INTEGER	Sí	FK→users.id	—
retention_records	tenant_id	INTEGER	No	IDX	—
retention_records	created_at	DATETIME	No	—	now()

3.2 Diccionario físico — bloque 16 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
retention_records	updated_at	DATETIME	No	—	now()
retention_execution_logs	id	INTEGER	No	PK; IDX	—
retention_execution_logs	policy_id	INTEGER	Sí	FK→retention_policies.id	—
retention_execution_logs	executed_by_id	INTEGER	Sí	FK→users.id	—
retention_execution_logs	records_processed	INTEGER	No	—	0
retention_execution_logs	records_exceptions	INTEGER	No	—	0
retention_execution_logs	status	VARCHAR(50)	No	—	SUCCESS
retention_execution_logs	log_details	JSON	No	—	callable
retention_execution_logs	run_type	VARCHAR(50)	No	—	MANUAL
retention_execution_logs	tenant_id	INTEGER	No	IDX	—
retention_execution_logs	created_at	DATETIME	No	—	now()
retention_execution_logs	updated_at	DATETIME	No	—	now()
legal_documents	id	INTEGER	No	PK; IDX	—
legal_documents	doc_type	VARCHAR(50)	No	IDX	—
legal_documents	title	VARCHAR(255)	No	—	—
legal_documents	version	VARCHAR(50)	No	—	—
legal_documents	effective_date	DATE	No	—	—
legal_documents	parameters	JSON	No	—	callable
legal_documents	content	TEXT	No	—	—
legal_documents	is_current	BOOLEAN	No	IDX	True

3.2 Diccionario físico — bloque 17 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
legal_documents	created_by_id	INTEGER	Sí	FK→users.id	—
legal_documents	tenant_id	INTEGER	No	IDX	—
legal_documents	created_at	DATETIME	No	—	now()
legal_documents	updated_at	DATETIME	No	—	now()
catalog_entries	id	INTEGER	No	PK; IDX	—
catalog_entries	type	VARCHAR(100)	No	IDX	—
catalog_entries	code	VARCHAR(100)	No	IDX	—
catalog_entries	label	VARCHAR(255)	No	—	—
catalog_entries	description	TEXT	No	—	—
catalog_entries	is_active	BOOLEAN	No	—	True
catalog_entries	sensitivity	VARCHAR(20)	Sí	IDX	—
catalog_entries	criticality	VARCHAR(20)	Sí	IDX	—
catalog_entries	version	INTEGER	No	—	1
catalog_entries	updated_by_id	INTEGER	Sí	FK→users.id	—
catalog_entries	tenant_id	INTEGER	No	IDX	—
catalog_entries	created_at	DATETIME	No	—	now()
catalog_entries	updated_at	DATETIME	No	—	now()
training_programs	id	INTEGER	No	PK; IDX	—
training_programs	title	VARCHAR(255)	No	—	—
training_programs	description	TEXT	No	—	—

3.2 Diccionario físico — bloque 18 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
training_programs	is_active	BOOLEAN	No	—	True
training_programs	tenant_id	INTEGER	No	IDX	—
training_programs	created_at	DATETIME	No	—	now()
training_programs	updated_at	DATETIME	No	—	now()
training_modules	id	INTEGER	No	PK; IDX	—
training_modules	program_id	INTEGER	No	IDX; FK→training_programs.id	—
training_modules	title	VARCHAR(255)	No	—	—
training_modules	description	TEXT	No	—	—
training_modules	order	INTEGER	No	—	0
training_modules	tenant_id	INTEGER	No	IDX	—
training_modules	created_at	DATETIME	No	—	now()
training_modules	updated_at	DATETIME	No	—	now()
training_materials	id	INTEGER	No	PK; IDX	—
training_materials	module_id	INTEGER	No	IDX; FK→training_modules.id	—
training_materials	title	VARCHAR(255)	No	—	—
training_materials	content_type	VARCHAR(50)	No	—	text
training_materials	url	VARCHAR(1024)	Sí	—	—
training_materials	content	TEXT	No	—	—
training_materials	tenant_id	INTEGER	No	IDX	—
training_materials	created_at	DATETIME	No	—	now()

3.2 Diccionario físico — bloque 19 de 19

Tabla	Campo	Tipo	Nulo	Clave / relación	Predeterminado
training_materials	updated_at	DATETIME	No	—	now()
enrollments	id	INTEGER	No	PK; IDX	—
enrollments	user_id	INTEGER	No	IDX; FK→users.id	—
enrollments	program_id	INTEGER	No	IDX; FK→training_programs.id	—
enrollments	enrolled_at	DATETIME	Sí	—	—
enrollments	completed_at	DATETIME	Sí	—	—
enrollments	progress_pct	INTEGER	No	—	0
enrollments	tenant_id	INTEGER	No	IDX	—
enrollments	created_at	DATETIME	No	—	now()
enrollments	updated_at	DATETIME	No	—	now()
backup_records	id	INTEGER	No	PK; IDX	—
backup_records	tenant_id	INTEGER	Sí	IDX	—
backup_records	filename	VARCHAR(500)	No	—	—
backup_records	checksum_sha256	VARCHAR(64)	No	—	—
backup_records	size_bytes	INTEGER	No	—	0
backup_records	status	VARCHAR(50)	No	—	COMPLETED
backup_records	notes	TEXT	No	—	—
backup_records	created_at	DATETIME	No	IDX	now()
backup_records	verified_at	DATETIME	Sí	—	—

Restricciones únicas compuestas observadas: roles(tenant_id,name); role_permissions(role_id,module); platform_permissions(user_id,permission).

4. Relaciones e integridad

4.1 Relaciones explícitas

Origen	Destino	ON DELETE	ON UPDATE
action_plans.template_id	action_plan_templates.id	No declarado	No declarado
action_plans.risk_assessment_id	risk_assessments.id	No declarado	No declarado
action_plans.created_by_id	users.id	No declarado	No declarado
alerts.recipient_id	users.id	No declarado	No declarado
arco_requests.assigned_dpo_id	users.id	No declarado	No declarado
audit_findings.audit_plan_id	audit_plans.id	No declarado	No declarado
audit_findings.created_by_id	users.id	No declarado	No declarado

Origen	Destino	ON DELETE	ON UPDATE
audit_logs.user_id	users.id	No declarado	No declarado
audit_plans.auditor_id	users.id	No declarado	No declarado
catalog_entries.updated_by_id	users.id	No declarado	No declarado
consent_records.treatment_activity_id	treatment_activities.id	No declarado	No declarado
consent_records.created_by_id	users.id	No declarado	No declarado
cookie_banners.created_by_id	users.id	No declarado	No declarado
cookie_consent.banner_id	cookie_banners.id	No declarado	No declarado
departments.head_user_id	users.id	No declarado	No declarado
dpia_assessments.treatment_activity_id	treatment_activities.id	No declarado	No declarado
dpia_assessments.signed_by_id	users.id	No declarado	No declarado
enrollments.user_id	users.id	No declarado	No declarado
enrollments.program_id	training_programs.id	No declarado	No declarado
incidents.department_id	departments.id	No declarado	No declarado
incidents.assigned_to_id	users.id	No declarado	No declarado
incidents.reporter_id	users.id	No declarado	No declarado
information_assets.treatment_activity_id	treatment_activities.id	No declarado	No declarado
information_assets.department_id	departments.id	No declarado	No declarado
information_assets.owner_id	users.id	No declarado	No declarado
legal_documents.created_by_id	users.id	No declarado	No declarado
platform_permissions.user_id	users.id	No declarado	No declarado
remediations.responsible_id	users.id	No declarado	No declarado
remediations.risk_assessment_id	risk_assessments.id	No declarado	No declarado
remediations.created_by_id	users.id	No declarado	No declarado
retention_execution_logs.executed_by_id	users.id	No declarado	No declarado
retention_execution_logs.policy_id	retention_policies.id	No declarado	No declarado
retention_records.policy_id	retention_policies.id	No declarado	No declarado
retention_records.information_asset_id	information_assets.id	No declarado	No declarado
retention_records.reviewed_by_id	users.id	No declarado	No declarado
risk_assessments.analyst_id	users.id	No declarado	No declarado
risk_assessments.treatment_activity_id	treatment_activities.id	No declarado	No declarado
role_permissions.role_id	roles.id	No declarado	No declarado
training_materials.module_id	training_modules.id	No declarado	No declarado
training_modules.program_id	training_programs.id	No declarado	No declarado
treatment_activities.owner_id	users.id	No declarado	No declarado

Origen	Destino	ON DELETE	ON UPDATE
treatment_activities.department_id	departments.id	No declarado	No declarado
users.department_id	departments.id	No declarado	No declarado

HALLAZGO Ninguna FK cargada desde la metadata declara ondelete u onupdate. Las operaciones destructivas deben anticipar el comportamiento predeterminado del motor y probarse en una copia restaurada.

4.2 Reglas y brechas de integridad

Control	Evidencia	Acción operativa
Identificador	id entero PK en las entidades observadas	Conservar valores en restauraciones; no reasignar PK manualmente.
Unicidad	tenants.ruc y users.email; además roles(tenant_id,name), role_permissions(role_id,module), platform_permissions(user_id,permission)	Validar conflictos antes de importar datos.
Estados	Numerosos estados se almacenan como VARCHAR/JSON	La lista permitida depende de validación de aplicación; no asumir CHECK de BD.
Tenancy	tenant_id indexado pero sin FK física	Pruebas negativas de acceso cruzado son obligatorias.
Auditoría	audit_logs se describe como append-only por diseño	No se encontró trigger o restricción DB que impida UPDATE/DELETE; tratarlo como convención de aplicación.
SQLite FK	No se encontró hook de PRAGMA foreign_keys	Confirmar `PRAGMA foreign_keys` por conexión antes de depender de enforcement local.

5. Migraciones y cambios de esquema

Revisión	Fecha	Antecesor	Cambio observable
9ea2fa322267	2026-05-18	base	Esquema base; crea 30 tablas.
b1f2a3c4d5e6	2026-07-24	9ea2fa322267	Agrega 10 campos SSPDP al modelo de incidentes.
b1f2b4650c86	2026-07-25	9ea2fa322267	Agrega roles y role_permissions.
c9d1e2f3a4b5	2026-08-05	b1f2b4650c86	Agrega users.account_scope y platform_permissions.
d4e5f6a7b8c9	2026-08-07	b1f2a3c4d5e6 + c9d1e2f3a4b5	Merge de ramas; sin cambio de esquema.

VERIFICADO `alembic heads` devuelve una sola cabeza: d4e5f6a7b8c9.

5.1 Runbook de migración

1. Abrir ticket de cambio: objetivo, revisión objetivo, responsable, ventana, impacto, plan de reversión y evidencia.
2. Resolver DATABASE_URL mediante el gestor aprobado; no imprimir la URI ni pasar la contraseña en la línea de comandos.
3. Obtener respaldo verificable y restaurarlo en un entorno aislado antes de migrar producción.
4. Ejecutar `alembic current`, `alembic heads` y `alembic history`; detener si hay cabezas inesperadas.
5. Aplicar `alembic upgrade head` en el entorno de prueba restaurado; ejecutar pruebas de integridad y aplicación.
6. En la ventana aprobada, pausar escrituras si el cambio lo requiere y ejecutar la migración una sola vez.
7. Registrar revisión anterior/nueva, tiempo, logs sin secretos y resultados de validación.
8. Reanudar tráfico solo tras health checks, prueba funcional y monitoreo de errores/latencia.

Comandos de inspección y avance

```
cd <DATALEGAL_BACKEND_DIR>
alembic current
alembic heads
alembic history --verbose
alembic upgrade head
```

DECISIÓN DE REVERSIÓN No asumir que un downgrade es seguro. Preferir restauración o migración correctiva según pérdida aceptable, compatibilidad del código y prueba previa. La decisión debe quedar en el ticket antes de la ventana.

Fuente verificable: backend/alembic/env.py; backend/alembic/versions/*.py; backend/tests/test_alembic_baseline.py.

6. Configuración local y de pruebas

6.1 Ejecución local

Modo	Motor observable	Inicio controlado
Local directo	SQLite en archivo por valor predeterminado	Entorno Python; Alembic para esquema; seed solo fuera de producción.
Docker Compose	PostgreSQL 16 Alpine con volumen postgres_data	Backend ejecuta `alembic upgrade head`, luego seed de desarrollo y Uvicorn con reload.
Pruebas	Archivo SQLite test_datalegal.db	El fixture observado usa un archivo, aunque su docstring lo describe como memoria.

SEGURIDAD `init\_db.py` limita create_all/drop_all a desarrollo/pruebas. Producción debe usar Alembic. `seed\_dev.py` se bloquea en producción y contiene credenciales de demostración en código: no copiarlas, no promoverlas y rotarlas si alguna vez se reutilizaron.

6.2 Variables — nombres, nunca valores

Grupo	Variables observables	Tratamiento
Base	ENVIRONMENT, DATABASE_URL	Injectar por entorno o gestor de secretos; restringir lectura.
Autenticación	SECRET_KEY, ALGORITHM, ACCESS_TOKEN_EXPIRE_MINUTES	SECRET_KEY fuerte y no registrada en logs.
MFA	MFA_ENCRYPTION_KEY, MFA_TOKEN_EXPIRE_MINUTES	Clave separada y rotación planificada.
Perímetro	CORS_ORIGINS, TRUSTED_PROXIES, SHOW_DOCS	Lista explícita en producción; revisar proxies.
Protección	MAX_FAILED_ATTEMPTS, LOCKOUT_MINUTES, AUTH_RATE_LIMIT, MFA_RATE_LIMIT	Aprobar valores por riesgo y capacidad.
Seed	SEED_DEV_DATA, SEED MOCK_DATA, DEV MOCK_DATASET, DEV_*	Solo desarrollo; nunca exportar credenciales o datos demo a producción.
Bootstrap	BOOTSTRAP_TENANT_*, BOOTSTRAP_ADMIN_*	Uso único y auditado; retirar variables sensibles después del bootstrap.

Plantilla sin valores sensibles

```
export ENVIRONMENT=<development|test|production>
export DATABASE_URL=<RESOLVER_DESDE_GESTOR_DE_SECRETOS>
alembic upgrade head
```

6.3 Bootstrap de producción

`bootstrap\_prod.py` exige las variables de tenant y administrador, reutiliza tenant por RUC y usuario por correo, y rechaza un usuario existente que no sea SUPER_ADMIN. Ejecútelo una sola vez bajo cambio aprobado y no conserve la contraseña en el historial.

Fuente verificable: backend/app/core/config.py; backend/app/db/init_db.py; backend/app/db/seed_dev.py; backend/app/db/bootstrap_prod.py; backend/tests/conftest.py; docker-compose.yml.

7. AWS parametrizable y decisiones de plataforma

LÍMITE DE VERIFICACIÓN El repositorio contiene una guía y un script AWS, pero este manual no consultó una cuenta AWS. No se confirman región, instancia, distribución, DNS, buckets, KMS, snapshots ni RDS activos.

7.1 Topología descrita por el repositorio

Elemento	Evidencia de repositorio	Estado en este manual
Cómputo	Plantilla EC2 con Docker	Diseño observable; recurso vivo no validado.
Base	Contenedor PostgreSQL 16 con volumen Docker sobre almacenamiento de la instancia	Diseño observable; persistencia real no validada.
Disco	Raíz gp3 cifrada en la plantilla	Propiedad de plantilla; cifrado del recurso real no validado.
Acceso	Rol/SSM y CloudFront aparecen en el script	Recursos vivos, políticas e IDs no validados.
Respaldo	No se encontró automatización S3/KMS/RDS en el script	Brecha a resolver antes de aceptar el RPO/RTO.

7.2 Parámetros obligatorios

Placeholder	Decisión requerida	Propietario
<AWS_ACCOUNT_ID>	Cuenta autorizada	Plataforma/seguridad
<AWS_REGION>	Región aprobada y requisitos de residencia	Arquitectura/legal
<INSTANCE_ID>	Instancia o conjunto de instancias DataLegal	Plataforma
<DB_HOST>, <DB_PORT>, <DB_NAME>, <DB_USER>	Conexión PostgreSQL sin contraseña en el documento	DBA/gestor de secretos
<S3_BACKUP_BUCKET>	Destino de respaldos con bloqueo público	Plataforma/seguridad
<KMS_KEY_ARN>	Clave de cifrado con política mínima	Seguridad
<BACKUP_ROLE_ARN>	Rol para escribir objetos y usar KMS	IAM/seguridad
<ALERT_TOPIC_ARN>	Canal de alertas y escalamiento	Operaciones

7.3 Opciones de respaldo AWS

Opción	Aplicabilidad	Controles mínimos	Decisión
EC2/EBS actual	Si PostgreSQL sigue en contenedor sobre disco EC2	pg_dump cifrado a S3; snapshot EBS coordinado con quiesce/stop; copia entre cuentas/regiones si se aprueba	Definir consistencia, ventana y recuperación del host.
RDS futuro	Solo si se adopta un servicio administrado	Automated backups/PITR, snapshots cifrados y prueba de restore	No está confirmado ni desplegado por este manual.

SEGURIDAD DE CONFIGURACIÓN La documentación de despliegue existente advierte sobre un archivo de entorno rastreado con una credencial. Este manual no leyó ni reproduce ese valor. Acción: rotar la credencial, remover el secreto de archivos e historial y conservar solo ejemplos sin valores.

Fuente verificable: docs/deployment-aws.md y deploy/aws/deploy-datalegal.sh; no se realizaron llamadas AWS.

8. Estado actual del respaldo

Componente	Comportamiento implementado	Limitación
scripts/backup.py	Copia SQLite con shutil.copy2, calcula y vuelve a calcular SHA-256	Puede copiar una BD activa de forma inconsistente; no cifra ni restaura.
Retención CLI	Ordena `backup_*.db` y elimina hasta quedar en el número configurado	El parámetro se denomina retention_days, pero funciona como cantidad, no edad.
API SQLite	SUPER_ADMIN copia el archivo, calcula SHA-256 y crea BackupRecord COMPLETED	La copia ocurre antes del registro; el artefacto puede no contener su propio registro.
API PostgreSQL	Crea BackupRecord PENDING con nota para pg_dump manual	No ejecuta pg_dump ni genera archivo.
Verify API	Recalcula SHA-256 y marca VERIFIED o FAILED	No ejecuta PRAGMA integrity_check ni una restauración funcional.

ARTEFACTOS VERIFICADOS Se inspeccionaron 12 archivos SQLite existentes: 5 hashes SHA-256 distintos, tamaños observados 659456 bytes, modos 0o644, integrity_check=ok y conteos de tablas [33]. La inspección fue de solo lectura.

RIESGO Los archivos observados tienen permisos 0644 y no presentan un contenedor de cifrado. SHA-256 detecta cambios, pero por sí solo no demuestra autenticidad, confidencialidad ni capacidad de restauración.

8.1 Qué no está demostrado

- ☐ Que exista un cron activo, una regla EventBridge, un job CI/CD o un scheduler externo ejecutando respaldos.
- ☐ Que exista almacenamiento externo, inmutable, replicado o cifrado para los artefactos actuales.
- ☐ Que PostgreSQL tenga respaldos automáticos o recuperación a un punto en el tiempo.
- ☐ Que el objetivo RPO ≤ 24 h / RTO ≤ 4 h declarado en el script haya sido aprobado o validado.

Fuente verificable: backend/scripts/backup.py; backend/app/api/v1/backups.py; backend/app/models/backup.py; backend/backups/backup_*.db.

9. Estrategia de respaldo objetivo

OBJETIVO DECLARADO EN CÓDIGO El script expresa RPO ≤ 24 horas y RTO ≤ 4 horas. Se conserva como objetivo de origen, pendiente de aprobación y de un simulacro cronometrado; no es un SLA validado.

9.1 Capas recomendadas

Capa	SQLite	PostgreSQL	Validación
Completo lógico	API `sqlite3 .backup` a archivo nuevo	pg_dump formato custom	Checksum + lectura estructural + restore aislado.
Físico	Snapshot consistente del volumen con la app detenida si se usa	Snapshot EBS coordinado si permanece en EC2; backup nativo si cambia de plataforma	Restaurar volumen/servicio en entorno aislado.
Fuera del host	Objeto cifrado en destino aprobado	Objeto cifrado en destino aprobado	HEAD/metadatos, checksum, acceso por rol y prueba de descarga.
Inmutable	Versionado/Object Lock si se aprueba	Versionado/Object Lock si se aprueba	Intento controlado de borrado/alteración según política.

9.2 Respaldo consistente de SQLite

Plantilla propuesta

```
umask 077
mkdir -p <BACKUP_STAGING_DIR>
sqlite3 <SQLITE_DB_PATH> ".timeout 5000" ".backup
'<BACKUP_STAGING_DIR>/<ARTIFACT>.db'"
sha256sum <BACKUP_STAGING_DIR>/<ARTIFACT>.db > <BACKUP_STAGING_DIR>/<ARTIFACT>.sha256
sqlite3 -readonly <BACKUP_STAGING_DIR>/<ARTIFACT>.db "PRAGMA integrity_check;"
```

En macOS puede usarse `shasum -a 256` si `sha256sum` no está disponible. No use `cp`/`copy2` como estrategia principal sobre una base activa, especialmente con WAL.

9.3 Respaldo lógico PostgreSQL

Plantilla propuesta sin contraseña en argumentos

```
umask 077
export PGPASSFILE=<RUTA_SEGURA_FUERA_DEL_REPO>
pg_dump --host <DB_HOST> --port <DB_PORT> --username <DB_USER> --dbname <DB_NAME> \
--format=custom --no-owner --no-acl --file <BACKUP_STAGING_DIR>/<ARTIFACT>.dump
pg_restore --list <BACKUP_STAGING_DIR>/<ARTIFACT>.dump >
<BACKUP_STAGING_DIR>/<ARTIFACT>.toc
shasum -a 256 <BACKUP_STAGING_DIR>/<ARTIFACT>.dump >
<BACKUP_STAGING_DIR>/<ARTIFACT>.sha256
```

9.4 Retención y cifrado

Control	Propuesta inicial	Aprobación requerida
Retención GFS	14 diarios, 8 semanales, 12 mensuales	Legal, negocio, seguridad y capacidad; no es política vigente.
Cifrado local	umask 077 y archivo 0600; cifrado antes de salir del host	Herramienta y custodia de claves.

Control	Propuesta inicial	Aprobación requerida
S3	Block Public Access, versionado y SSE-KMS con <KMS_KEY_ARN>	Bucket, región, rol y política KMS.
Inmutabilidad	Object Lock en modo y plazo aprobados	Impacto legal, costos y procedimiento de excepción.
Eliminación	Lifecycle después del plazo + bitácora	Hold legal y doble aprobación para borrado manual.

9.5 Automatización y alertas

- ☐ Job idempotente con bloqueo para impedir ejecuciones simultáneas.
- ☐ Nombre UTC único, manifiesto externo y estado STARTED/COMPLETED/FAILED/VERIFIED.
- ☐ Timeout, reintentos limitados y fallo visible; nunca éxito silencioso.
- ☐ Alerta por ausencia de respaldo dentro del RPO, checksum fallido, subida fallida, espacio bajo o restore drill vencido.
- ☐ Métricas: antigüedad del último respaldo verificado, duración, tamaño, tasa de cambio y fecha del último simulacro.
- ☐ Logs estructurados sin credenciales, URI de conexión ni datos personales.

10. Restauración paso a paso

REGLA DE ORO Nunca restaure directamente sobre producción como primera prueba. Conserve el origen, restaure en un destino aislado, valide y obtenga autorización antes del corte.

10.1 Preparación común

1. Declarar incidente/cambio, responsable, autoridad para decidir, alcance y hora objetivo.
2. Detener o aislar escrituras; preservar logs, artefactos y la base afectada.
3. Seleccionar el respaldo por hora UTC, estado, checksum, esquema y cumplimiento del RPO.
4. Copiar el artefacto a staging seguro; verificar checksum contra un manifiesto separado.
5. Crear entorno aislado con versión compatible del motor y del código.

10.2 Restauración SQLite

Destino aislado

```
umask 077
shasum -a 256 -c <ARTIFACT>.sha256
sqlite3 -readonly <ARTIFACT>.db "PRAGMA integrity_check; PRAGMA foreign_key_check;"
sqlite3 <RESTORE_DB_PATH> ".restore '<ARTIFACT>.db'"
sqlite3 -readonly <RESTORE_DB_PATH> "PRAGMA integrity_check; PRAGMA
foreign_key_check;"
```

1. Comparar conteo de tablas con 33 y confirmar `alembic\_version` en la revisión esperada.
2. Iniciar la aplicación apuntando solo al archivo restaurado y ejecutar smoke tests.
3. Si se promueve, detener aplicación, conservar el archivo dañado, intercambiar rutas de forma atómica y ajustar permisos 0600.
4. Reabrir tráfico gradualmente, observar errores y documentar reconciliación de datos posteriores al punto restaurado.

10.3 Restauración PostgreSQL

Destino aislado

```
export PGPASSFILE=<RUTA_SEGURA_FUERA_DEL_REPO>
shasum -a 256 -c <ARTIFACT>.sha256
pg_restore --list <ARTIFACT>.dump
createdb --host <DB_HOST> --port <DB_PORT> --username <DB_USER> <RESTORE_DB>
pg_restore --host <DB_HOST> --port <DB_PORT> --username <DB_USER> --dbname
<RESTORE_DB> \
--exit-on-error --clean --if-exists --no-owner --no-acl <ARTIFACT>.dump
```

Si el destino está vacío, `--clean --if-exists` es redundante pero deja explícita la intención. Si existen objetos ajenos, no use `--clean` sin revisar el listado. Ajuste propietarios y grants mediante un paso aprobado después de restaurar.

10.4 Validación y promoción

Plano	Criterio mínimo	Responsable
Estructura	alembic_version, 33 tablas esperadas, tipos y FK críticas	DBA/ingeniería
Integridad	Consultas de huérfanos, unicidad, nulabilidad y tenant scoping	DBA/QA
Aplicación	Login, lectura/escritura controlada, módulos críticos y permisos	QA/propietario
Seguridad	Roles, secretos, permisos de archivo/objeto y auditoría	Seguridad
Negocio	Muestras reconciliadas por tenant y fecha; datos posteriores al RPO identificados	Propietario de datos
Promoción	Aprobación, plan de corte, rollback y comunicación	Incident commander

11. RPO, RTO y niveles de servicio

Nivel	RPO objetivo	RTO objetivo	Diseño mínimo	Estado
Origen	≤24 h	≤4 h	Respaldo diario y restore verificado	Declarado en código; no validado.
Mejorado	<RPO_APROBADO>	<RTO_APROBADO>	Mayor frecuencia/PITR + automatización + capacidad reservada	Decisión futura; no implementada.
Desarrollo	Mejor esfuerzo	Mejor esfuerzo	Copias locales sin datos sensibles	No usar para compromisos de producción.

11.1 Cómo medir

- ☐ RPO real = hora del incidente menos hora del último punto restaurable y verificado.
- ☐ RTO real = hora de declaración hasta servicio validado y autorizado, no solo hasta terminar ``pg_restore``.
- ☐ Separar tiempos: detección, decisión, obtención, restauración, validación, corte y comunicación.
- ☐ Registrar el peor caso y los percentiles de simulacros; actualizar capacidad y procedimientos.

CRITERIO DE ACEPTACIÓN El objetivo solo se convierte en compromiso operativo después de dos simulacros consecutivos exitosos en condiciones representativas, con margen acordado y responsables de guardia.

12. Validación continua y simulacros

12.1 Validación por respaldo

- ☐ Checksum calculado en origen y verificado tras transporte.
- ☐ Lectura de catálogo: ``sqlite3`` o ``pg_restore --list`` sin errores.
- ☐ Validación estructural y de revisión Alembic.
- ☐ Restore automatizado periódico en destino efímero y aislado.
- ☐ Smoke tests de API con datos sintéticos o minimizados.
- ☐ Eliminación segura del destino efímero y conservación de evidencia no sensible.

12.2 Simulacro trimestral propuesto

Fase	Evidencia	Momento
------	-----------	---------

Fase	Evidencia	Momento
Preparar	Escenario, punto objetivo, observadores, datos permitidos, ventana y criterios	T-7 días
Detectar	Emitir alerta simulada y activar árbol de escalamiento	T0
Restaurar	Obtener, verificar, restaurar y documentar cada marca de tiempo	Cronometrado
Validar	Integridad, aplicación, seguridad y negocio	Antes de declarar éxito
Cerrar	Calcular RPO/RTO, brechas, responsables y fechas	≤2 días hábiles
Reprobar	Repetir después de corregir cualquier criterio fallido	Fecha aprobada

12.3 Criterios de éxito

- ☐ Artefacto y manifiesto disponibles sin privilegios excesivos.
- ☐ Checksum, estructura y aplicación válidos.
- ☐ RPO y RTO medidos dentro del objetivo aprobado.
- ☐ No se exponen secretos ni datos personales en logs o capturas.
- ☐ El equipo puede ejecutar el runbook sin conocimiento tácito del autor.
- ☐ Las brechas tienen ticket, propietario y fecha.

13. Recuperación por escenarios

Escenario	Contención	Recuperación	Validación crítica
Borrado accidental	Aislar escrituras y determinar hora/tenant	Restore aislado; extraer/importar conjunto mínimo si es posible	Validar referencias y aislamiento tenant
Migración defectuosa	Detener rollout y preservar revisión previa	Elegir migración correctiva, downgrade probado o restore	Compatibilidad código/esquema y datos posteriores
Corrupción SQLite	Copiar evidencia; no seguir escribiendo	Seleccionar último `integrity_check=ok`; restaurar archivo	integrity_check + foreign_key_check + API
Pérdida de host EC2	No depender del volumen perdido	Reconstruir host desde IaC y restaurar dump/snapshot externo	Red, secretos, grants, aplicación y DNS
Credencial comprometida	Revocar/rotar primero; preservar logs	Restaurar solo si hay alteración; usar credenciales nuevas	Auditar acceso, integridad y alcance temporal
Ransomware	Aislar, activar respuesta a incidentes	Usar copia inmutable previa; reconstruir limpio	Escaneo, identidad, cadena de custodia
Solicitud por tenant	Confirmar base legal y alcance	No existe dump tenant implementado; diseñar exportación lógica con FK completas	Pruebas de no inclusión de otros tenants
Backup corrupto	Marcar FAILED y preservar evidencia	Probar siguiente punto; investigar cadena	Restauración completa, no solo checksum

DATOS POSTERIORES AL PUNTO Toda restauración puede descartar transacciones posteriores al punto elegido. Identifique, exporte y reconcilie esos cambios cuando sea seguro; documente la pérdida aceptada y su autorización.

14. Seguridad y auditoría

Área	Control	Evidencia
Acceso	Cuenta/rol exclusivo de backup; lectura de BD y escritura solo al prefijo requerido	Revisión trimestral
Secretos	PGPASSFILE o gestor de secretos; nunca argumentos, documentos, repositorio ni logs	Rotación y alerta de uso
Cifrado	TLS en tránsito; cifrado de artefacto; SSE-KMS en destino aprobado	Prueba de descifrado controlada
Integridad	SHA-256 + manifiesto separado y protegido; inmutabilidad si se aprueba	Verificación al crear, transferir y restaurar
Permisos	0600 local y propietario dedicado	Scan automático de modos
Auditoría	Actor, tenant/alcance, UTC, artefacto, resultado y ticket	Logs append-only fuera del host
Privacidad	Minimización, acceso justificado, entorno aislado y borrado post-drill	Evidencia sin PII
Separación	Operador ejecuta; segundo aprobador autoriza restore/borrado	Doble control

14.1 Eventos mínimos de auditoría

- ☐ Inicio/fin/fallo de respaldo, con duración y tamaño.
- ☐ Cálculo y verificación de checksum; nunca registrar credenciales.
- ☐ Carga, copia, retención, hold y eliminación del artefacto.
- ☐ Descarga, descifrado, restauración, promoción y descarte del entorno de prueba.
- ☐ Cambios de política IAM/KMS/bucket/scheduler y modificaciones del runbook.

LIMITACIÓN DEL MODELO BackupRecord admite tenant_id opcional y la copia SQLite contiene todos los tenants. El permiso SUPER_ADMIN en la API reduce acceso, pero no reemplaza aislamiento físico, cifrado ni auditoría externa.

15. Checklists operativos

15.1 Antes de respaldar

- ☐ Ticket/ejecución programada y responsable identificados.

- ☐ Motor, origen y punto de consistencia confirmados.
- ☐ Destino con espacio, permisos mínimos y cifrado disponibles.
- ☐ Secrets resueltos fuera del comando y del log.
- ☐ No existe otra ejecución con el mismo origen/destino.

15.2 Después de respaldar

- ☐ Comando terminó con código cero.
- ☐ Tamaño razonable frente al historial.
- ☐ Checksum y catálogo/estructura válidos.
- ☐ Artefacto transferido al destino protegido.
- ☐ Registro COMPLETED y luego VERIFIED con fecha UTC.
- ☐ Alerta de antigüedad del último respaldo quedó verde.

15.3 Antes de restaurar

- ☐ Autoridad, alcance, hora objetivo y pérdida aceptable aprobados.
- ☐ Escrituras aisladas y evidencia preservada.
- ☐ Artefacto, manifiesto y versiones compatibles seleccionados.
- ☐ Destino aislado preparado; no apunta a producción.
- ☐ Rollback de la restauración y comunicación listos.

15.4 Antes de promover

- ☐ Integridad estructural y referencial aprobada.
- ☐ Revisión Alembic esperada.
- ☐ Pruebas funcionales, de permisos y tenant negativas aprobadas.
- ☐ Reconciliación de datos posteriores documentada.
- ☐ Aprobación de negocio, seguridad y responsable del incidente.
- ☐ Monitoreo intensivo y umbral de rollback activos.

16. Bitácoras y registros

16.1 Bitácora de respaldo

Campo	Valor
ID / ticket	<BACKUP_RUN_ID> / <TICKET>
Inicio / fin UTC	<YYYY-MM-DDThh:mm:ssZ> / <YYYY-MM-DDThh:mm:ssZ>
Operador / aprobador	<OPERADOR> / <APROBADOR>
Motor / origen	<SQLITE POSTGRESQL> / <ORIGEN_NO_SECRETO>
Artefacto / tamaño	<ARTIFACT_ID> / <BYTES>
Checksum	<SHA256> (manifiesto separado)
Destino / cifrado	<DESTINO> / <KMS_KEY_ALIAS_O_MECANISMO>
Resultado	<COMPLETED FAILED VERIFIED>
Validaciones	<INTEGRIDAD> / <RESTORE_TEST_ID>
Observaciones	<SIN_SECRETOS_NI_PII>

16.2 Bitácora de restauración/simulacro

Campo	Valor
Incidente / simulacro	<ID> / <TIPO>
Escenario / alcance	<ESCENARIO> / <TENANTS_O_MODULOS>
Punto objetivo UTC	<YYYY-MM-DDThh:mm:ssZ>
Artefacto	<ARTIFACT_ID> + checksum verificado
Marcas de tiempo	detección <...>; decisión <...>; restore <...>; servicio <...>
RPO medido	<DURACION>
RTO medido	<DURACION>
Validación	estructura <...>; aplicación <...>; seguridad <...>; negocio <...>
Pérdida/reconciliación	<DESCRIPCION_Y_AUTORIZACION>
Decisión final	<PROMOVER ABORTAR REPETIR>
Acciones	<TICKET> / <RESPONSABLE> / <FECHA>

Apéndice A. Comandos de consulta rápida

Comandos seguros cuando los placeholders ya están resueltos

```
# Esquema
alembic current
alembic heads
alembic history --verbose

# SQLite, solo lectura
sqlite3 -readonly <DB_PATH> "PRAGMA integrity_check; PRAGMA foreign_key_check;"

# PostgreSQL: inspección de dump
pg_restore --list <ARTIFACT>.dump
```

PRECAUCIÓN Los comandos destructivos (`dropdb`, `rm`, sobrescritura de archivo, `pg\_restore --clean`) requieren objetivo explícito, doble revisión y ventana aprobada. No se incluyen como atajos de emergencia.

Apéndice B. Registro de decisiones abiertas

ID	Decisión	Propietario	Fecha límite
DB-001	Motor y topología de producción realmente activos	Arquitectura/DBA	Antes de activar automatización
DB-002	RPO/RTO aprobados por servicio/tenant	Negocio/continuidad	Antes del primer SLA
DB-003	Retención legal y GFS	Legal/seguridad	Antes de lifecycle
DB-004	Bucket, región, rol y KMS	Plataforma/seguridad	Antes del primer respaldo externo
DB-005	Estrategia de snapshot consistente	DBA/plataforma	Antes de usar snapshots físicos
DB-006	PITR/RDS o permanencia en EC2	Arquitectura	Roadmap
DB-007	Exportación/restore por tenant	Producto/privacidad/DBA	Antes de prometer recuperación granular
DB-008	Frecuencia y propietario de simulacros	Continuidad	Antes de aprobar RTO
DB-009	Rotación/eliminación de credencial rastreada	Seguridad	Inmediato
DB-010	Corrección de retención CLI: edad vs cantidad	Ingeniería	Siguiente cambio del script

Apéndice C. Fuentes y trazabilidad

Tema	Ruta relativa a work/datalegal
Modelo y sesión	backend/app/db/base.py; backend/app/db/session.py; backend/app/models/*.py
Migraciones	backend/alembic/env.py; backend/alembic/versions/*.py; tests/test_alembic_baseline.py
Configuración/seed	backend/app/core/config.py; backend/app/db/init_db.py; seed_dev.py; bootstrap_prod.py
Respaldo	backend/scripts/backup.py; backend/app/api/v1/backups.py; backend/app/models/backup.py; tests de backups
Contenedores	docker-compose.yml; backend/Dockerfile
AWS	docs/deployment-aws.md; deploy/aws/deploy-datalegal.sh (solo evidencia de repositorio)
Marca	docs/guia-de-diseno-datalegal.md
Artefactos	backend/backups/backup_*.db, inspección SQLite read-only

Notas de control

- ☐ Los conteos del diccionario se generan desde la metadata SQLAlchemy en cada build.
- ☐ Los diagramas distinguen relaciones físicas de relaciones lógicas/operativas.
- ☐ Los placeholders entre `<` >` requieren resolución fuera del documento y sin registrar secretos.
- ☐ Las propuestas de AWS, retención, cifrado e inmutabilidad no se convierten en hechos desplegados.
- ☐ Próxima revisión: después de cualquier migración, cambio de topología o simulacro; como máximo trimestral.

FIN DEL MANUAL Conserve el DOCX aprobado en un repositorio documental con control de acceso y versiones. El runbook operativo debe permanecer disponible cuando la aplicación o su base de datos no lo estén.